

Report di Analisi Indicatori di Compromissione

Analisi Cattura di Rete Wireshark

THREAT INTELLIGENCE & IOC

DATA
05Giugno 2026

CLASSIFICAZIONE
Confidenziale

STATO
Incidente Attivo

LIVELLO SOC
Tier1→Tier 2

1. Sintesi

Il presente rapporto descrive i risultati dell'analisi di una cattura di traffico di rete effettuata con Wireshark (**Cattura_U3_W1_L5.pcapng**). L'analisi ha identificato un'attività di ricognizione in corso all'interno della rete locale: un dispositivo interno sta eseguendo una scansione sistematica delle porte su un secondo dispositivo, con l'obiettivo di individuare servizi attivi e potenziali punti di accesso.

Trattandosi di traffico originato da un indirizzo IP privato, la minaccia proviene dall'interno della rete locale stessa. Questo scenario rende l'incidente particolarmente critico, in quanto indica che un attaccante ha già ottenuto accesso alla rete e sta operando al suo interno.

2. Indicatori di Compromissione (IOC)

Durante l'analisi del file di cattura sono stati identificati i seguenti indicatori di compromissione:

 IP Sorgente (Attaccante)	192.168.200.100	Dispositivo interno che origina la scansione
IP Destinazione (Vittima)	192.168.200.150	Dispositivo interno preso di mira
Protocollo	TCP	Transmission Control Protocol
Tecnica di Scansione	TCP Connect Scan	Handshake TCP completo per ogni porta testata
Range Porte Scansionate	1 – 1024	Tutte le porte well-known
Volume Pacchetti	> 2000 pacchetti	Flood di SYN verso porte multiple in breve tempo
Flag TCP Osservati	SYN, SYN/ACK, RST/ACK	Pattern tipico e inequivocabile di port scanning

■ 3. Porte Aperte Identificate

Le seguenti porte hanno risposto con un pacchetto SYN/ACK, confermando la presenza di servizi attivi sulla macchina target 192.168.200.150:

Porta			
21	FTP	ALTO	Trasferimento file in chiaro, credenziali non cifrate
22	SSH	MEDIO	Accesso remoto sicuro se configurato correttamente
23	Telnet	CRITICO	Protocollo obsoleto, tutta la comunicazione viaggia in chiaro
25	SMTP	MEDIO	Servizio di posta, possibile relay non autorizzato
53	DNS	MEDIO	Possibile DNS spoofing o zone transfer non autorizzato
80	HTTP	MEDIO	Web server senza cifratura, traffico leggibile
111	RPC	ALTO	Remote Procedure Call, frequentemente sfruttato per escalation
139	NetBIOS	ALTO	Condivisione risorse Windows, storicamente vulnerabile
445	SMB	CRITICO	Protocollo di condivisione file, bersaglio di WannaCry ed EternalBlue
512	rexec	CRITICO	Esecuzione remota Unix senza cifratura
513	rlogin	CRITICO	Accesso remoto Unix obsoleto e privo di autenticazione sicura
514	rsh	CRITICO	Shell remota Unix, nessuna autenticazione richiesta

■ 4. Vettore di Attacco e Contesto

Tecnica identificata: TCP Connect Scan

La tecnica osservata prevede l'invio di un pacchetto SYN verso ciascuna porta nel range 1-1024. Se la porta è aperta, il sistema target risponde con SYN/ACK e la connessione viene completata (three-way handshake); se chiusa, risponde con RST/ACK. Questo pattern è compatibile con una scansione eseguita tramite strumenti come **Nmap** con i parametri **-sT -p 1-1024**.

Minaccia interna Lateral Movement

L'indirizzo IP sorgente 192.168.200.100 appartiene alla rete privata locale (RFC 1918). Questo indica che l'attività non proviene dall'esterno, ma da un dispositivo già presente all'interno della rete. Questo scenario è classificabile come **Lateral Movement** (MITRE ATT&CK T1046 Network Service Discovery): l'attaccante, dopo aver ottenuto accesso alla rete, sta mappando i servizi disponibili per individuare il prossimo obiettivo.

Nota: La presenza di un IP interno come sorgente esclude la possibilità di bloccare l'attacco semplicemente sul firewall perimetrale. Il dispositivo 192.168.200.100 deve essere considerato compromesso fino a prova contraria e trattato di conseguenza.

■ 5. Come Intervenire

Di seguito viene descritto il piano di risposta all'incidente, suddiviso per livello operativo all'interno del Security Operations Center (SOC). Il processo segue la catena di escalation standard: Tier 1 esegue il triage, Tier 2 gestisce la risposta, Tier 3 interviene solo se necessario.

TIER 1 Triage (Azione Immediata)

1. Confermare che l'attività rilevata non sia un falso positivo **confermato**.
2. Documentare tutti gli IOC raccolti: IP sorgente, IP destinazione, porte scansionate, porte aperte, tecnica utilizzata e timestamp.
3. Aprire un ticket di incidente e inviarlo al Tier 2 con il presente report allegato.
4. Continuare il monitoraggio per rilevare eventuali tentativi di accesso successivi alla scansione.

TIER 2 Incident Response

1. Ricevere il ticket dal Tier 1 e approfondire l'analisi correlando con altri log disponibili.
2. Isolare immediatamente il dispositivo **192.168.200.100** dalla rete, disabilitando la porta dello switch o spostandolo in una VLAN isolata.
3. Investigare l'identità del dispositivo: chi lo utilizza? È un asset aziendale? È stato compromesso da un attore esterno?
4. Verificare nei log se, successivamente alla scansione, ci sono stati tentativi di accesso ai servizi identificati (FTP, SSH, SMB, Telnet, rsh).
5. Applicare regole sul firewall interno per bloccare il traffico proveniente dall'IP sorgente verso il resto della rete.
6. Se l'incidente supera le capacità di risposta del Tier 2 o si rivela parte di un attacco più ampio, escalare al Tier 3.

TIER 3 Threat Hunting / Expert (se necessario)

1. Condurre un'analisi forense del dispositivo 192.168.200.100 per determinare come è stato compromesso e da quando.
2. Verificare se la scansione fa parte di una campagna di attacco più ampia rivolta all'intera infrastruttura.
3. Revisione completa delle regole firewall e delle policy di segmentazione della rete interna.
4. Hardening della macchina target: disabilitare immediatamente i servizi non necessari, in particolare Telnet (23), rexec (512), rlogin (513) e rsh (514).

■ 6. Conclusioni e Raccomandazioni

L'analisi della cattura di rete ha portato all'identificazione di un'attività di ricognizione attiva in corso all'interno della rete locale. La presenza di un TCP Connect Scan su tutte le porte well-known (1-1024), originato da un indirizzo IP interno, rappresenta un segnale di allarme che non può essere classificato come falso positivo.

La combinazione di porte critiche aperte sulla macchina target in particolare SMB (445), Telnet (23) e i servizi Unix remoti (512, 513, 514) rende il sistema altamente vulnerabile a un attacco successivo alla fase di ricognizione. Si raccomanda un'azione immediata di contenimento e una revisione completa della postura di sicurezza dell'intera infrastruttura di rete.

La sicurezza informatica non è un prodotto da installare, ma un processo continuo. Incidenti come questo sottolineano l'importanza di un monitoraggio costante della rete, della corretta segmentazione degli asset e della disattivazione dei servizi obsoleti che rappresentano una superficie di attacco inutilmente esposta.
